

Paypal Manager Account Hijack

Paypal Manager Account Hijack - Mark Litchfield, Publisher not stated.

- Published: date not stated
- Original:
<<https://web.archive.org/web/20140516030049/http://www.securatary.com/Portals/0/Vulnerabilities/PayPal/Paypal%20Manager%20Account%20Hijack.pdf>>
- Preserved from:
<https://web.archive.org/web/20140516030049/http://www.securatary.com/Portals/0/Vulnerabilities/PayPal/Paypal%20Manager%20Account%20Hijack.pdf> (manual-import) on 2026-08-07
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

--- page 1 ---

Author Mark Litchfield - mark[at]Securatory[dot]com For all new vulnerabilities
<http://twitter.com/securatary> PayPal Manager Admin Account Hijack

--- page 2 ---

What is PayPal Manager PayPal Manager is used to manage your Payflow account Summary:

--- page 3 ---

This attack required a number of steps and obstacles to overcome in order to hijack another Admins merchant account by means of changing their password. PayPal had gone to considerable lengths (more so than others) to ensure the security of this portal. In short the hack consisted of:

- 1) Enumeration of account information requiring a valid Partner ID and Vendor ID to request a new password. We needed valid account information
- 2) After entering valid credentials you are then prompted for a security question in-order for an email to be sent containing the password reset link. So we need an attack to bypass the security question
- 3) After entering the correct information, and email is sent to the registered address containing a link. We needed an attack to be able to get this link / bypass / the email link process
- 4) Once you have successfully changed your password, you are then presented with another security screen asking for yet another security question as (based on a live hack), you are logging in for the first time from a different IP address. So we needed an attack to bypass the security question or IP address restriction
- 5) Once in, you have access to the administrators PII and their customers. And seeing as my last few attacks allow for free shopping, why stop there. Place an order, then using the virtual terminal go and credit your money back to your account / credit card Alternatively you could just manually create your

own order and charge yourself a \$1.00. The Hack: Step (1) - Account Enumeration At this point we select Customize and Preview and catch our request within Burp

--- page 4 ---

Send your GET request to Intruder In our example, we are simply going to use the builtin username dictionary that comes with Burp

--- page 5 ---

Ëcp*€Đç†ßV³¶¶ðîîµfÚÃæ,,æbS×<íqëBp¿ÿ_™ĐC¨ÚÎ,òpY,1Ç*³=è}iéuo-
Ä¶ñÜDóÃf\$Jà²g!GQÿzÄû\$ãÄÑÅa,vÖĐÈœya¶ÜÁîxÁÝÆ_LÓïmué&íÄp>œlOÚ<éU×çåfœ{fŽçèo6«\$"Ü
3_Ú¨¶8œ™™yGý@~_ÆšûD?gûG·,mÛ×9ézáMÖ,n¯'M@ \$pVÆ"±"+¶ô»A,p0:_Ö}BçÁ?
ØúezT[x@!³üš3»ŽlâŽf¶¶:YµM>pY"šúÖû4óÂ?ûàPSéqN@-Ä\$à™P¿'iQÆpy,, -ÆNïÿ@?
»İİÿiGÛÿžÿß€ö/ô!mæ·v9?6êoöjeO~ûQÁz"Ÿİp·'Üÿžÿß³Aÿ<#ÿ¾Gž"µš

--- page 6 ---

Start your enumeration If a response contains a length of around 1800 2010 bytes we do not have a winner, as shown below.

--- page 7 ---

++++
++++

--- page 8 ---

Lengths greater than 2010 are winners

--- page 9 ---

So looking at a login screen, we can now fill two of the required three parameters Step (2)
Bypassing the Security Question To do this, we need to first reset our own password. The following screens show this process.

--- page 10 ---

++++
++++

--- page 11 ---

At this point, catch your POST request and send to Repeater to be used again shortly

--- page 12 ---

Continue to Login, but select Forgot password feature. In this example, we are attacking another merchant account I set up Here is the POST request, what is important to note is we are re-using the same token. So once hackthis

--- page 13 ---

++++
++++

--- page 14 ---

[illegible]

[illegible]

[illegible]

[illegible]

--- page 20 ---

[illegible]

This step had me really stuck and I decided to submit the vulnerability anyway to Paypal as we could access some features (limited) through the PayFlow API. This kept eating at me though, to get this far and to then be shut down by an IP Address. So I decided to revisit this step. My initial problem I was too focused on the security question and not the real problem, my current IP address. After much dicking around, I decided upon trying the X-Forwarded-For header - the X-Forwarded-For (XFF) HTTP header field is a de facto standard for identifying the originating IP address of a client connecting to a web server through an HTTP proxy or load balancer. To test this, I set up an IP restriction within PayPal manager setting both my cell phone IP address (in case I locked myself out because X-Forwarded-For did not work) and also the IP address of manager.paypal.com. I am looking for errors or the security question to appear to determine if the X-Forwarded-For header is being obeyed. First test, I am using the IP address of http://manager.paypal.com Having set the IP restriction on manager.paypal.com, I tried to log in from my usual IP address. This should fail if the X-Forwarded-For header IS being obeyed.

--- page 24 ---

þý8Zj²ÄCR6N%GkQîú;XC&s=gR>*,',TzM.TG8 5Rn/L5p]#;OýÝ:X<p87Rayð9b³;+;ÿè³M+;ÿð³M+;ÿì³
M+;ÿî³M+;ÿè³M+¾¾3/!&,²S»*50.± V?ýÔî?ýÔî/á++++ÖÄ10%#".54>32#".#"32>32@_{|-Ë◆MS-
Ñ8jZF2OqOV◆d75c◆[MsQ4 ·/%L%%"L

Archived from <https://web.archive.org/web/20140516030049/http://www.securatary.com/Portals/0/Vulnerabilities/PayPal/Paypal%20Manager%20Account%20Hijack.pdf>. Rendered offline from the local Markdown copy.